Actividad individual de análisis técnico y fundamentación

Caso: Infraestructura de Grupo DeltaCom

Nombre:	Fecha:	Grupo:
Modalidad: individual	Tiempo sugerido: 2 horas	Producto: dictamen técnico

Indicaciones de trabajo

- Analice el caso como responsable de revisar la seguridad del servicio. No se proporciona una lista de fallas ni una cantidad mínima de errores a encontrar.
- Fundamente sus decisiones con documentación técnica oficial. No se aceptan recomendaciones sustentadas únicamente en opiniones, blogs o respuestas sin fuente.
- No copie definiciones completas. La consulta debe utilizarse para explicar por qué una recomendación es pertinente para DeltaCom.
- Toda afirmación tomada de una fuente deberá citarse en formato APA dentro del texto, por ejemplo: (Ross & Pillitteri, 2024) o (Canonical, s. f.).
- Priorice. No todos los hallazgos tienen el mismo impacto ni requieren atenderse en el mismo orden.
- En cada control propuesto explique cómo comprobaría que funciona y qué riesgo seguiría existiendo después de aplicarlo.

Fuentes obligatorias de consulta

Las fuentes siguientes se utilizarán como referencia técnica. NIST SP 800-171 Rev. 3 se consulta por sus principios de control de acceso y mínimo privilegio; no se asume que DeltaCom esté sujeto a requisitos de CUI.

Fuente	Qué consultar	Acceso
NIST SP 800-171 Rev. 3	Consultar 03.01.01 Gestión de cuentas; 03.01.04 Separación de funciones; 03.01.05 Mínimo privilegio; 03.01.06 Cuentas privilegiadas; 03.01.07 Funciones privilegiadas; 03.01.08 Intentos de inicio de sesión; 03.01.09 Notificación de uso.	Abrir fuente oficial
Ubuntu Server - OpenSSH server	Consultar funcionamiento de sshd, archivos de configuración, autenticación y uso de llaves públicas.	Abrir fuente oficial
Ubuntu Server - Firewall	Consultar Netfilter/UFW, firewall de host, reglas y restricción de acceso por servicio, puerto u origen.	Abrir fuente oficial
Ubuntu Security - Full Disk Encryption	Consultar LUKS, cifrado a nivel de bloque, mecanismos de desbloqueo y protección de datos en reposo.	Abrir fuente oficial

Lectura dirigida

Durante la consulta, registre notas breves. No se busca resumir los documentos completos, sino localizar criterios que puedan aplicarse al caso.

Fuente	Pregunta de lectura
NIST	Identifique dos requisitos que puedan aplicarse a cuentas, privilegios o separación de responsabilidades en DeltaCom.
OpenSSH	Identifique una recomendación o mecanismo que ayude a reducir el riesgo del acceso administrativo remoto y explique qué debería verificarse.
Firewall	Explique qué información necesita conocer antes de decidir qué tráfico permitir o bloquear en un servidor.
LUKS	Explique qué escenario de riesgo reduce el cifrado de almacenamiento y qué limitación conserva cuando el volumen ya está desbloqueado.

Caso empresarial: Grupo DeltaCom

Grupo DeltaCom ofrece instalación y soporte de enlaces de comunicación para pequeñas y medianas empresas. Cuenta con aproximadamente 80 trabajadores y utiliza un servidor Linux para alojar un sistema web interno denominado ControlNet. El servicio concentra información necesaria para operación, soporte y seguimiento de clientes.

Información administrada por ControlNet. El sistema almacena datos de clientes, contratos de servicio, direcciones, documentos de identificación, reportes técnicos, datos de equipos instalados y registros de atención. Parte de esta información es consultada por personal administrativo y de soporte; otra parte solo debería estar disponible para quienes administran la infraestructura.

Usuarios y privilegios. Existen las cuentas admininfra, webadmin, soporte y proveedor. admininfra administra el sistema operativo; webadmin mantiene la aplicación; soporte atiende incidentes y revisa servicios; proveedor fue creado para un técnico externo. Durante una revisión se observa que soporte puede realizar prácticamente cualquier acción administrativa mediante privilegios elevados. La cuenta proveedor continúa activa varias semanas después de finalizar el trabajo y no tiene una fecha de expiración definida.

Acceso remoto. El servidor tiene SSH habilitado para administración. La autenticación mediante contraseña está disponible y varios integrantes del área técnica conocen las credenciales de una cuenta administrativa. También existen llaves SSH utilizadas para automatizar respaldos, pero no hay un inventario claro de quién conserva copias, desde qué equipos se usan ni qué acciones permite cada llave.

Red y servicios. El servidor se encuentra dentro de la red interna de la empresa. ControlNet debe estar disponible para los trabajadores y SSH se utiliza para administración. El firewall de host no tiene una política documentada y existen varios servicios escuchando en el servidor cuya utilidad actual no está registrada. El responsable considera que la red interna es suficiente protección porque el servidor no se publica directamente hacia Internet.

Archivos sensibles. La configuración de la aplicación contiene información necesaria para conectarse a la base de datos. El archivo puede ser leído y modificado por más usuarios de los necesarios. En otro directorio se almacenan contratos y documentos de clientes. Existen permisos del sistema de archivos, pero no se ha analizado si estos controles son suficientes frente a todos los escenarios de riesgo.

Almacenamiento. Los respaldos y documentos históricos se guardan en un segundo volumen conectado al servidor. El volumen utiliza un sistema de archivos convencional y se monta automáticamente al iniciar. Si el disco fuera retirado y conectado a otro equipo, la empresa no ha implementado un mecanismo adicional que impida leer directamente su contenido.

Verificación y evidencia. El responsable de infraestructura afirma que varias configuraciones ya fueron aseguradas, pero no conserva evidencia técnica reciente. No existe un registro claro que demuestre qué usuarios pueden ejecutar funciones privilegiadas, qué servicios son accesibles desde otros equipos, qué mecanismos de autenticación acepta SSH o qué información permanecería protegida si se perdiera físicamente un dispositivo de almacenamiento.

Trabajo individual

A partir del caso y de las fuentes consultadas, elabore un dictamen técnico. Debe identificar situaciones relevantes, valorar su riesgo y proponer controles que puedan comprobarse.

1. Matriz de análisis

Reproduzca la estructura de la matriz en su libreta o documento digital y registre al menos cinco hallazgos distintos. Utilice citas APA en la columna de fundamentación cuando su decisión se apoye en una fuente.

Situación encontrada	Riesgo e impacto	C / I / D	Control propuesto	Fundamento técnico / fuente	Cómo verificaría el control

2. Decisiones de priorización

1. Seleccione los tres riesgos que atendería primero. Justifique el orden de prioridad considerando impacto, exposición y función del servicio.

2. Determine qué cuentas necesitan privilegios administrativos y cuáles deberían operar con privilegios limitados. Justifique con base en las funciones descritas.

3. Antes de modificar SSH, ¿qué información revisaría y qué evidencia obtendría del estado actual?

4. ¿Qué comunicaciones necesita realmente ControlNet? Explique qué información utilizaría para decidir qué debe permitir el firewall de host.

5. En el caso de los archivos de configuración y documentos de clientes, explique cuándo son necesarios permisos del sistema operativo, cuándo es necesario cifrado y cuándo conviene utilizar ambos.

6. Explique qué riesgo existiría si una llave privada utilizada para respaldos fuera copiada por una persona no autorizada. Proponga controles para reducir ese riesgo.

7. Explique qué riesgo reduce cifrar el segundo volumen con LUKS y mencione al menos una situación que el cifrado del volumen no resolvería por sí solo.

8. Seleccione uno de los controles propuestos y diseñe una prueba positiva y una prueba negativa que permitan demostrar que el control funciona.

3. Síntesis técnica

Redacte una conclusión de entre 150 y 250 palabras que responda: ¿qué patrón general de debilidad observa en DeltaCom y qué estrategia de protección debería seguir la empresa? La conclusión debe integrar al menos dos de las fuentes consultadas, no repetir la matriz.

Criterios de revisión

- Distingue correctamente situación, vulnerabilidad o debilidad, riesgo, impacto y control.
- Relaciona los controles con funciones reales del servicio y aplica el principio de mínimo privilegio.
- Diferencia protección mediante permisos, autenticación, firewall y cifrado.
- Utiliza documentación técnica oficial para fundamentar decisiones y cita en formato APA.
- Propone verificaciones observables: qué debería funcionar, qué debería rechazarse y qué evidencia demostraría el resultado.
- Reconoce limitaciones del control y riesgo residual; evita presentar una herramienta como solución absoluta.

Referencias para consulta

Ross, R., & Pillitteri, V. (2024). Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations (NIST SP 800-171 Rev. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-171r3 Fuente oficial

Canonical. (s. f.). OpenSSH server. Ubuntu Server documentation. Fuente oficial

Canonical. (s. f.). Firewall. Ubuntu Server documentation. Fuente oficial

Canonical. (s. f.). Full disk encryption (FDE). Ubuntu security documentation. Fuente oficial

The GnuPG Project. (s. f.). GnuPG manuals. Fuente complementaria para cifrado de archivos y administración de llaves. Fuente oficial

Nota sobre las fuentes

Las publicaciones se utilizan como bibliografía técnica para analizar principios y mecanismos de seguridad. La selección de un control para DeltaCom debe justificarse a partir del contexto del caso; citar una recomendación no sustituye el análisis de su pertinencia.

Cómo utilizar las fuentes en el dictamen

Cita en el texto. Cuando una decisión se apoye en NIST puede utilizar, según corresponda, (Ross & Pillitteri, 2024). Para la documentación de Ubuntu puede utilizar (Canonical, s. f.). La cita debe acompañar una explicación propia de cómo el criterio se aplica a DeltaCom.

Fundamentación. No basta con mencionar una fuente. Debe relacionar el criterio consultado con el riesgo identificado, el control seleccionado y la forma en que comprobaría su funcionamiento.

Entregable al finalizar la actividad

- Matriz con al menos cinco hallazgos distintos.
- Respuesta razonada a las ocho preguntas de priorización y análisis.
- Síntesis técnica de 150 a 250 palabras.
- Citas dentro del texto y referencias de las fuentes efectivamente utilizadas.
- Controles acompañados de una propuesta de verificación y de su riesgo residual.